

Aula 2 (Módulo 15) — Incidente Simulado Completo

Vamos aplicar as sete fases da Aula 1 a um incidente completo, retomando o cenário que já construímos ao longo do curso (Word malicioso → PowerShell → persistência, Módulos 02, 10 e 13). Depois, como sempre, o convite para conduzir sua própria resposta a incidente ao vivo.

O incidente

Resumo inicial (o que se sabia no momento em que virou incidente): Ana, do time financeiro, abriu um anexo de e-mail (`fatura_setembro.docx`) às 09h14. O EDR (Módulo 10) gerou um alerta de severidade Alta às 09h15 (PowerShell oculto, filho do Word, com `-enc`). O analista N1 escalou para N2 (Módulo 08); N2 confirmou True Positive às 09h32 e abriu um incidente.

Preparation (o que já existia, antes disso acontecer)

- EDR instalado em todas as estações (Módulo 10) — é o que gerou o alerta inicial.
- Playbook de "execução suspeita via Office" já documentado, definindo que qualquer ocorrência desse padrão deve ser escalada como Alta automaticamente.
- Backup diário das estações de trabalho, testado mensalmente.

Identification

- **Host:** `WKS-FINANCEIRO-07`
- **Usuário:** `ana.silva`
- **Processo inicial:** `powershell.exe` (PID 4821), pai `winword.exe` (PID 3102)
- **Timestamp:** 2026-09-19 09:14-09:32 (do e-mail até a confirmação)
- **Escopo inicial conhecido:** um único host, aparentemente

Triage

- Severidade: Alta (host de usuário do time financeiro — não é o ativo mais crítico da empresa, mas dados financeiros têm valor alto para um atacante).
- Prioridade: atendido imediatamente (nenhum outro incidente concorrente nesse momento).

Containment

Decisão tomada às 09:35: isolar o host `WKS-FINANCEIRO-07` da rede imediatamente (contenção de curto prazo, via EDR) — a investigação preliminar (Event ID 3, Sysmon) já mostrava uma conexão de saída estabelecida para um IP externo, então o risco de exfiltração em andamento pesou mais que o valor de "observar mais" antes de conter.

Eradication — a investigação de causa raiz completa

Aplicando a metodologia do Módulo 13, Aula 2:

1. **Command line decodificada** (Base64 → texto): revelou um script que baixava um segundo estágio de `hxxp://185.220.101[.]47/update.ps1` e o executava na memória.
2. **Busca por persistência** (lembra sempre de verificar o que MAIS foi criado): encontrada a Run key `WindowsUpdateHelper` apontando para `svhost.exe` em `%APPDATA%` (Sysmon Event ID 13 e 11).
3. **Hash do `svhost.exe`** verificado contra VirusTotal (Módulo 12) — identificado como uma variante de um infostealer conhecido.
4. **Escopo confirmado**: revisão do e-mail original mostrou que o mesmo anexo foi enviado a **3 outros funcionários** — dois não abriram o anexo (confirmado via log de e-mail), um terceiro (`carlos.mendes`) abriu, mas o EDR não gerou alerta lá (motivo investigado à parte — descoberto que o EDR daquela máquina estava com uma atualização de assinatura atrasada).
5. **Ação de erradicação**: remoção da Run key e do `svhost.exe` em ambos os hosts afetados; bloqueio do IP `185.220.101.47` e do domínio de origem no firewall/proxy (Módulo 03/04); reforço da política de execução de macro (Módulo 02, Aula 5) para bloquear macros de arquivos com "Mark of the Web".

Recovery

- Ambos os hosts reconstruídos a partir de imagem limpa (não apenas "limpos" — reconstruídos do zero, por precaução, já que um infostealer pode ter coletado credenciais antes da contenção).
- Senhas de `ana.silva` e `carlos.mendes` resetadas por precaução (o infostealer pode ter capturado credenciais antes do isolamento).
- Monitoramento reforçado nos dois hosts pelas próximas 2 semanas.

Lessons Learned

Reunião realizada 5 dias depois, com as seguintes conclusões documentadas:

1. **Lacuna encontrada**: o EDR de `carlos.mendes` estava com assinatura desatualizada — **ação**: implementar alerta automático para agentes EDR desatualizados há mais de 24h (isso se torna, depois, uma nova regra de detecção — Módulo 21).
2. **O que funcionou bem**: o playbook de escalção automática para "execução suspeita via Office" funcionou exatamente como documentado, reduzindo o tempo entre alerta e contenção para 21 minutos.
3. **Melhoria de prevenção**: bloqueio de macro reforçado (Preparation melhorada para o próximo incidente parecido).
4. **IOCs documentados** e compartilhados internamente (e, se a política da empresa permitir, com a comunidade — conectando de volta com Threat Intelligence, Módulo 12) para os outros times reconhecerem esse padrão no futuro.

O relatório final (estrutura)

Um relatório de incidente profissional normalmente inclui:

1. Resumo executivo (2-3 frases, para quem não vai ler tudo)
2. Timeline completa (do primeiro evento até a resolução)
3. Escopo (hosts/usuários afetados)
4. IOCs (hashes, IPs, domínios)
5. Técnicas ATT&CK envolvidas (Módulo 13)
6. Ações de contenção/erradicação/recovery tomadas
7. Lições aprendidas e ações de melhoria (com responsável e prazo)

Isso é exatamente o tipo de documento que vale a pena praticar escrever e guardar em `reports/` neste repositório — é uma peça de portfólio extremamente forte (Módulo 07, Aula 3), porque demonstra o processo completo, não só conhecimento teórico.

Como praticar sua própria resposta a incidente

Quando quiser, me peça: *"quero conduzir uma resposta a incidente"* — vou te dar um cenário inicial (parecido com o resumo do início desta aula) e você conduz as sete fases, tomando decisões reais (isolar agora ou observar mais? qual a causa raiz? qual o escopo completo?), com dados que vou fornecendo conforme você investiga — sem eu entregar o incidente já resolvido, exatamente como fizemos nos Módulos 08 e 14.

Recapitulando o Módulo 15

- Um incidente completo aplica as sete fases em sequência, mas com decisões reais em cada uma (isolar quando? causa raiz completa, não só sintoma; escopo sempre verificado além do óbvio).
- Erradicação exige confirmar a causa raiz e todo o escopo — parar cedo demais é a razão mais comum de reinfecção.
- Lessons Learned transforma o incidente em melhoria concreta de Preparation e Detection Engineering — sem isso, o aprendizado se perde.
- Um relatório de incidente bem escrito é uma das peças mais fortes de portfólio que você pode construir.

Módulo 15 concluído. 🎉

Próximo módulo

Módulo 16 — Digital Forensics: aprofundando a coleta e análise de evidência que sustenta cada uma dessas fases — timeline, artefatos de sistema de arquivos, memória, e mais.

Fontes recomendadas

- **NIST SP 800-61 Rev. 2:** já citada — cobre também a estrutura de relatório de incidente e comunicação durante a resposta. <https://csrc.nist.gov/pubs/sp/800/61/r2/final>
- **CISA — "Incident Reporting":** orientações oficiais sobre o que documentar e, em certos setores regulados, quando reportar incidentes a autoridades. <https://www.cisa.gov/report>

